

Tomcat服务安全加固

笔记本：应用服务加固

创建时间：2018/11/2 21:27

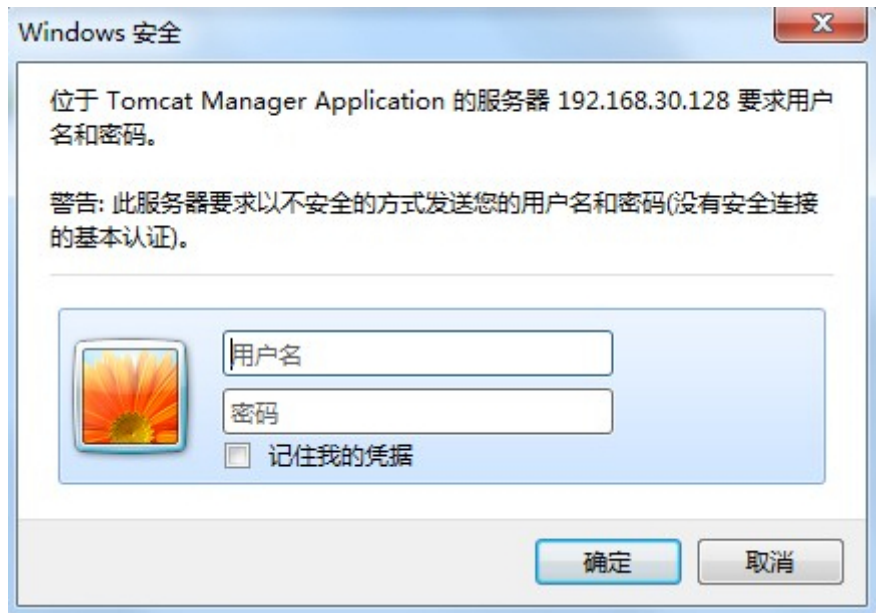
更新时间：2018/11/2 21:27

作者：苏醒

URL：https://help.aliyun.com/knowledge_detail/37421.html?spm=a2c4g.11186631.2.2.452c45578b8khq

Tomcat服务默认启用了管理后台功能，使用该后台可直接上传 war 文件包对站点进行部署和管理。由于运维人员的疏忽，可能导致管理后台存在空口令或者弱口令的漏洞，使得黑客或者不法分子可以利用该漏洞直接上传 Webshell 脚本导致服务器沦陷。

通常 Tomcat 后台管理的 URL 地址为 <http://IP:8080/manager/html/>，如下图所示：



黑客通过猜解到的口令登录 Tomcat 管理后台后，可以上传 Webshell 脚本导致服务器被入侵。

安全加固方案

由于此类型漏洞可能对业务系统造成比较严重的危害，建议您针对 Tomcat 管理后台进行以下安全加固配置。

1. 网络访问控制

如果您的业务不需要使用 Tomcat 管理后台管理业务代码，建议您使用[安全组防火墙](#)功能对管理后台 URL 地址进行拦截，或直接将 Tomcat 部署目录中 webapps 文件夹中的 manager、host-manager 文件夹全部删除，并注释 Tomcat 目录中 conf 文件夹中的 tomcat-users.xml 文件中的所有代码。

如果您的业务系统确实需要使用 Tomcat 管理后台进行业务代码的发布和管理，建议为 Tomcat 管理后台配置强口令，并修改默认 admin 用户，且密码长度不低于10位，必须包含大写字母、特殊符号、数字组合。

2. 开启 Tomcat 的访问日志

修改 conf/server.xml 文件，将下列代码取消注释：

```
<Valve className="org.apache.catalina.valves.AccessLogValve" directory="logs"
prefix="localhost_access_log." suffix=".txt" pattern="common" resolveHosts="false"/>
```

启用访问日志功能，重启 Tomcat 服务后，在 tomcat_home/logs 文件夹中就可以看到访问日志。

3. Tomcat 默认帐号安全

修改 Tomcat 安装目录 conf 下的 tomcat-user.xml 文件，重新设置复杂口令并保存文件。重启 Tomcat 服务后，新口令即生效。

4. 修改默认访问端口

修改 conf/server.xml 文件把默认的 8080 访问端口改成其它端口。

5. 重定向错误页面

修改访问 Tomcat 错误页面的返回信息，在 webapps\manager 目录中创建相应的401.html、404.htm、500.htm 文件，然后在 conf/web.xml 文件的最后一行之前添加下列代码：

```
<error-page>
<error-code>401</error-code>
<location>/401.htm</location>
</error-page>
<error-page>
<error-code>404</error-code>
<location>/404.htm</location>
</error-page>
<error-page>
<error-code>500</error-code>
<location>/500.htm</location>
</error-page>
```

6. 禁止列出目录

防止直接访问目录时由于找不到默认页面，而列出目录下的文件的情况。

在 web.xml 文件中，将<param-name>listings</param-name>改成<param-name>>false</param-name>。

7. 删除文档和示例程序

删除 webapps 目录下的 docs、examples、manager、ROOT、host-manager 文件夹。